

Гібридний постквантовий протокол автентифікації на основі парольного ключового обміну OPAQUE з інтеграцією ML-KEM-768: побудова, формальний аналіз та відтворювана реалізація

Олександр Мельниченко

Ecliptix Security, Україна

Анотація Парольна автентифікація залишається одним із базових механізмів підтвердження особи в сучасних інформаційних системах, однак протоколи парольного автентифікованого ключового обміну, зокрема OPAQUE, спираються на класичні припущення складності для Діффі–Геллмана та еліптичних кривих. Поява масштабованих квантових обчислень робить такі припущення стратегічно вразливими, а сценарій «збирай зараз — дешифруй пізніше» переводить проблему з довгострокової теоретичної перспективи у площину прикладного планування.

У статті запропоновано Hybrid PQ-OPAQUE — реалізаційно орієнтоване гібридне розширення OPAQUE, у якому ML-KEM-768 (FIPS 203) інтегровано до 4DH-контур автентифікованого ключового обміну. Сеансовий ключ виводиться за допомогою HKDF-Extract із чотирьох значень Діффі–Геллмана на Ristretto255 та спільного секрету ML-KEM-768 із транскриптно залежною сіллю. На відміну від суто концептуальних описів гібридних PAKE, у роботі фіксується повний мережевий формат повідомлень, включно з префіксом версії, контекстним зв'язуванням ідентифікатора облікового запису acst, детермінованим виведенням OPRF-ключа з кореневого секрету σ_{oprf} та окремим включенням постквантових компонент до транскрипту і схеми виведення ключів.

Аргументація спирається на три взаємодоповнювальні рівні. ProVerif 2.05 застосовано в окремих моделях секретності та автентифікації; Tamarin Prover 1.10.0 використано для сурогатної 4DH-моделі, де архівований запуск підтверджує 8/8 лем за 22,83 с; Rust-реалізацію перевірено детерміністичними, інтеграційними та властивісними тестами. У сукупності ці матеріали формують сильну, хоча й не абсолютну, доказову базу: вони не підміняють повного формального доведення коду реалізації, а твердження про офлайн-стійкість інтерпретуються лише для сценарію компрометації бази даних без компрометації σ_{oprf} .

Реалізацію виконано мовою **Rust 1.93.1**; пакет дослідницьких матеріалів охоплює понад 5,3 тис. рядків основного коду, майже 4,0 тис. рядків тестів і 1,46 тис. рядків еталонних вимірювань. На платформі

Apple M1 Pro повний цикл автентифікації становить 481,43 мс, повний раунд ML-KEM-768 — 122,01 мкс, тоді як домінантний внесок у латентність дає Argon2id (510,86 мс в ізольованому вимірюванні). Постквантовий шар додає 159,3 мкс процесорного часу до повного ключового обміну без KSF і збільшує повний обсяг рукописання до 2715 байт без зміни кількості раундів. Порівняно з класичним OPAQUE це означає адитивне й контрольоване зростання складності для чесних сторін і жорсткішу умову компрометації ключового матеріалу в прийнятій моделі. Отримані результати показують, що перехід до постквантово-підсиленої парольної автентифікації є практично досяжним уже нині, а головний компроміс пов'язаний передусім із мережевим обсягом повідомлень, а не з додатковими обчисленнями.

Keywords: OPAQUE, PAKE, ML-KEM-768, постквантова криптографія, гібридний ключовий обмін, Ristretto255, HKDF, Tamarin, ProVerif, Rust

1 Вступ

1.1 Актуальність проблеми

Парольна автентифікація залишається поширеним механізмом підтвердження особи в сучасних розподілених інформаційних системах. За різними оцінками, понад 80% процедур автентифікації у веб-додатках та мережевих сервісах базуються на паролях [1,2]. Протоколи парольного автентифікованого ключового обміну (PAKE) забезпечують встановлення захищеного каналу між двома сторонами, що поділяють спільний секрет низької ентропії — пароль — без розкриття цього паролю противнику [3]. Серед відомих протоколів PAKE протокол OPAQUE [4], запропонований Jarecki, Krawczyk та Xu у 2018 році, належить до добре проаналізованих представників класу асиметричних PAKE (у міжнародній літературі — augmented PAKE): сервер зберігає лише криптографічний запис, який не є паролем еквівалентом при компрометації лише бази даних [5]. Для практичних реалізацій ця властивість потребує явного окреслення межі довіри: компрометація глобального секрету, з якого деривуються OPRF-ключі, відрізняється від компрометації пасивного сховища записів і не може ототожнюватися з тим самим сценарієм безпеки.

1.2 Квантова загроза

У 1994 році Пітер Шор запропонував квантовий алгоритм [6], здатний розв'язувати задачу дискретного логарифмування за поліноміальний час на квантовому комп'ютері. Цей алгоритм безпосередньо загрожує всім криптосистемам на основі DLP та ECDLP: RSA, ECDH, а також будь-якому PAKE-протоколу, що будується на їх основі [7]. За оцінками, для зламу Ristretto255/Curve25519 достатньо криптографічно значущого квантового комп'ютера з приблизно 2 330 логічними кубітами [8]. Водночас новіші оцінки

для 256-бітної еліптичнокривої криптографії над `secp256k1` вказують на ще жорсткіший сценарій: Google Quantum AI у whitepaper 2026 року наводить дві реалізації алгоритму Шора для ECDLP-256 з оцінками не більше ніж 1200 логічних кубітів і 90 млн Toffoli-операцій або не більше ніж 1450 логічних кубітів і 70 млн Toffoli-операцій [9]. Хоча ці числа не є прямою оцінкою саме для Ristretto255, вони підсилюють загальний висновок: криптосистеми на 256-бітних еліптичних кривих можуть виявитися практично вразливими раніше, ніж це впливало з попереднього покоління оцінок квантових ресурсів.

Особливу небезпеку становить стратегія «збирай зараз — дешифруй пізніше» [10]: противник зберігає зашифрований трафік сьогодні з метою ретроспективного криптоаналізу на квантовому комп'ютері в майбутньому. Для систем, що опрацьовують довготривалі конфіденційні дані, ця загроза є практично значущою вже зараз.

1.3 Стандартизація постквантової криптографії

У серпні 2024 року NIST опублікував перші стандарти постквантової криптографії: FIPS 203 (ML-KEM) [11] та FIPS 204 (ML-DSA) [12]. ML-KEM базується на задачі навчання з помилками на модульних решітках (Module-LWE), для якої не відомо ефективних квантових алгоритмів. Гібридні підходи (класика + постквантова складова) впроваджуються в TLS 1.3 [13], Signal (PQXDH) [14] та WireGuard [15].

1.4 Обмеження існуючих рішень

Класичний OPAQUE у поточній специфікації IETF [5] не містить механізмів захисту від квантових атак: ключовий матеріал класичного 4DH може бути відновлений алгоритмом Шора. Інші PAKE-протоколи (SRP, SPAKE2) є так само вразливими. Чисто постквантові PAKE вже активно розвиваються: з'явилися компактні KEM-базовані конструкції [29], UC/QROM-схеми для постквантового середовища [31] та перші формалізовані підходи до гібридного PAKE [30,32]. Водночас ці результати ще не привели до усталеного стандарту асиметричного PAKE на кшталт OPAQUE. Існуючі гібридні рішення (TLS 1.3, Signal, WireGuard) не адресують парольну автентифікацію. Окремою проблемою є розрив між абстрактними описами гібридних PAKE та відтворюваними матеріалами, придатними до незалежної перевірки: у відкритій літературі бракує робіт, які одночасно задають повний формат повідомлень протоколу, межі інтерпретації формальних результатів, експериментальну базу та відкриту реалізацію.

У найстислішому порівняльному формулюванні внесок цієї роботи полягає не в збільшенні кількості раундів чи радикальному ускладненні протоколу для чесних сторін, а в зміні структури компрометації ключового матеріалу. Порівняно з канонічним 3DH-OPAQUE запропонована схема зберігає фіксовано-раундову взаємодію та додає лише адитивні обчислювальні й комунікаційні витрати, але водночас переводить умову компрометації з суто

класичного рівня до двошарового гібридного комбінатора в межах прийнятої моделі.

1.5 Мета та завдання дослідження

Мета: розробка, формальний аналіз та реалізація гібридного постквантового протоколу на основі OPAQUE, що забезпечує одночасну стійкість до класичних та квантових атак без втрати фундаментальних властивостей безпеки aPAKE.

Завдання:

1. Розробити конструкцію гібридного комбінатора ключового матеріалу (4DH + ML-KEM-768).
2. Специфікувати розширений транскрипт із постквантовими елементами, контекстним зв'язуванням `asct` та версіонуванням повідомлень протоколу.
3. Побудувати багаторівневу доказову базу безпеки (редукційні ескізи, ProVerif, Tamarin, Rust-тести) з явним визначенням меж інтерпретації.
4. Реалізувати протокол мовою Rust та підготувати відкритий набір дослідницьких матеріалів для відтворення результатів.
5. Виміряти латентність, пропускну здатність та постквантові накладні витрати за допомогою статистичних еталонних вимірювань Criterion.
6. Оцінити практичну придатність конструкції для інтерактивної паролльної автентифікації на клієнтських і серверних вузлах.

1.6 Дослідницькі питання та критерії оцінювання

Для систематизації роботи сформульовано чотири дослідницькі питання.

- RQ1** Чи можна інтегрувати ML-KEM-768 до OPAQUE без збільшення кількості протокольних повідомлень і без втрати ключових властивостей aPAKE?
- RQ2** Яким чином слід поєднувати класичний 4DH-матеріал і KEM-секрет так, щоб уникнути атаки зниження рівня безпеки та зберегти транскриптне зв'язування?
- RQ3** Який обсяг формальної та експериментальної доказовості достатній, щоб робити стримані висновки про безпеку реалізації, не ототожнюючи символічну модель із кодом реалізації?
- RQ4** Чи є постквантовий шар практично прийнятним для інтерактивної паролльної автентифікації, якщо домінуючим компонентом латентності залишається Argon2id?

Критеріями оцінювання є: (1) відсутність додаткових раундів обміну; (2) наявність узгодженого опису мережевого формату повідомлень і криптографічного транскрипту; (3) наявність формальних моделей і реалізаційних матеріалів, які можна незалежно відтворити; (4) процесорні накладні витрати постквантового шару, що не домінують над вартістю функції жорсткого перетворення пароля; (5) чітко задокументована межа безпекових тверджень для сценаріїв компрометації секретів сервера.

1.7 Наукова новизна та внесок

1. **Гібридна 4DH + ML-KEM-768 конструкція.** Запропоновано реалізаційно орієнтований варіант Hybrid PQ-OPAQUE, у якому ML-KEM-768 є обов'язковою складовою ключового обміну, а не факультативним розширенням.
2. **Спеціалізований комбінатор ключового матеріалу.** $PRK = HKDF-Extract(salt_\tau, dh_1 || dh_2 || dh_3 || dh_4 || ss_{kem})$ із контекстно-залежною сіллю, що містить мічений геш розширеного транскрипту τ .
3. **Специфікація рівня реалізації.** Окрім постквантових елементів, транскрипт включає окремий хеш контексту облікового запису, а мережевий формат визначає 1-байтовий префікс версії та точні розміри повідомлень.
4. **Багаторівнева доказова база.** Для однієї й тієї самої конструкції узгоджено редукційні ескізи, дві ProVerif-моделі, Tamarin-модель із сурогатним поданням 4DH та Rust-тести.
5. **Відкрита реалізація та пакет дослідницьких матеріалів.** Оновлений простір проектів містить понад 5,3 тис. рядків основного Rust-коду, майже 4,0 тис. рядків тестів і окремі модулі мікрвимірювань, протокольних вимірювань та вимірювань пропускну здатності.
6. **Репродуковані емпіричні результати.** Показано, що постквантовий шар збільшує процесорні витрати ключового обміну на 159,3 мкс без KSF, тоді як домінуючим фактором латентності залишається Argon2id.

1.8 Термінологічні домовленості

Щоб уникнути змішування англійських і українських позначень, у подальшому викладі використовується термінологія, зафіксована в Табл. 1. Повторні вживання цих термінів слід читати саме в наведених тут значеннях.

Табл. 1. Термінологічні домовленості, прийняті в статті

Термін	Зафіксоване значення
Мережевий формат повідомлень	Повне байтове подання повідомлення на каналі, включаючи префікс версії та службові поля протоколу
Корисні дані	Вміст повідомлення без службового префікса версії та інших зовнішніх обгорт
Асиметричний РАКЕ (aРАКЕ)	Клас парольного автентифікованого ключового обміну, у якому сервер зберігає верифікатор, а не пароль у відкритому вигляді чи його прямий еквівалент
Схема виведення ключів	Послідовність процедур екстракції та розширення ключового матеріалу, що формує сеансові та допоміжні ключі
Пакет дослідницьких матеріалів	Сукупність вихідного коду, формальних моделей, тестів і еталонних вимірювань, достатніх для незалежного відтворення результатів

Крім того, у формальному викладі використовуються позначення $asst$ для ідентифікатора облікового запису та σ_{prf} для кореневого секрету, з

якого виводяться OPRF-ключі на стороні сервера. Буквальні ASCII-мітки доменного розділення надалі замінюються символами L_{oprf} , L_{seed} , L_{key} , L_{ksf} , L_{salt} , L_{ctx} , L_{τ} та L_{comb} ; для формального аналізу істотними є їх сталість і взаємна відмінність, а не конкретна текстова форма реалізаційного рядка.

2 Аналіз літературних джерел та існуючих рішень

2.1 Протоколи парольного автентифікованого ключового обміну

Парольний автентифікований ключовий обмін (PAKE) — клас протоколів, які дозволяють двом сторонам, що поділяють спільний секрет низької ентропії (пароль), встановити автентифікований сесійний ключ, стійкий до офлайн-атак за словником [16]. Протоколи PAKE поділяються на дві категорії:

- *Збалансовані (balanced) PAKE* — обидві сторони зберігають ідентичне парольне представлення. Приклади: EKE [17], SPAKE2 [18], CPace [19].
- *Асиметричні PAKE (aPAKE; у міжнародній літературі — augmented PAKE)* — сервер зберігає лише парольний верифікатор. Приклади: SRP [20], AuCPace [19], OPAQUE [4].

Табл. 2. Порівняльна характеристика протоколів PAKE

Властивість	EKE	SRP	SPAKE2	OPAQUE
Тип	Збалансований	Асиметричний	Збалансований	Асиметричний
Нееквівалентний серверний запис	Ні	Частково	Ні	Так
Стійкість до попередніх обчислень	Ні	Ні	Ні	Так
Пряма секретність	Так	Так	Так	Так
Стійкість до компрометації серверного сховища	Ні	Часткова	Ні	У моделі пасивної БД
Формальне доведення безпеки	ІС	Відсутнє	ROM	UC
Квантова стійкість	Ні	Ні	Ні	Ні

У Табл. 2 рядок для OPAQUE щодо компрометації серверного сховища слід читати у вузькому, але стандартному сенсі компрометації лише бази записів автентифікації. Він не охоплює компрометацію глобального серверного секрету, з якого можуть деривуватися OPRF-ключі.

2.2 Протокол OPAQUE: формальний опис

Протокол OPAQUE [4] складається з фази реєстрації та фази автентифікації, обидві спираються на механізм забутливої псевдовипадкової функції (OPRF). Стандартний IETF OPAQUE використовує потрійний обмін Діффі–Геллмана (3DH): $dh_1 = sk_S \cdot PK_C$ (взаємна автентифікація), $dh_2 = sk_S \cdot E_C$, $dh_3 = e_S \cdot PK_C$ (пряма секретність). У даній роботі додано **четвертий добуток** $dh_4 = e_S \cdot E_C$, який додатково зв’язує обидві ефемерні компоненти в одному транскрипті і на рівні 4DH-інтуїції покликаний ускладнити UKS-подібні

підстановки; у цій роботі це тлумачиться як дизайн-мотивація, а не як окремо доведена властивість. Це розширення є внеском даного дослідження. Безпека базового OPAQUE доведена в моделі Universal Composability (UC) [22].

Забутлива псевдовипадкова функція (OPRF). Реалізація використовує генування в групу Ristretto255 [21]:

$$\alpha = r \cdot H'(\text{ctx}||x), \quad \beta = k \cdot \alpha, \quad F_k(x) = r^{-1} \cdot \beta \quad (1)$$

де $r \xleftarrow{\$} \mathbb{Z}_q^*$ — випадковий скаляр засліплення на стороні клієнта, k — секретний ключ сервера.

2.3 Постквантова криптографія та стандарти NIST 2024

ML-KEM-768 обрано на рівні безпеки NIST рівня 3 (еквівалент AES-192). Параметри: $|pk| = 1184$ байт, $|ct| = 1088$ байт, $|ss| = 32$ байти, безпека IND-CCA2. Конструкція:

$$\text{KeyGen}() \rightarrow (pk, sk); \quad \text{Encaps}(pk) \rightarrow (ct, ss); \quad \text{Decaps}(sk, ct) \rightarrow ss. \quad (2)$$

2.4 Обґрунтування вибору ML-KEM-768

Вибір ML-KEM-768 у цій роботі не є випадковим. З одного боку, ML-KEM-512 пропонує менші повідомлення і нижчі накладні витрати, але орієнтується на NIST рівень 1. З іншого боку, ML-KEM-1024 надає вищий рівень запасу безпеки ціною відчутно більшого розміру повідомлень у мережевому форматі і більшого навантаження на транспорт. Для інтерактивної паролної автентифікації, де протокол уже містить відносно дорогий KSF, центральним стає не максимальний можливий запас безпеки сам по собі, а збалансованість між криптографічною стійкістю, розміром повідомлень та операційною придатністю.

За сукупністю цих міркувань ML-KEM-768 постає як виважений вибір для Hybrid PQ-OPAQUE. Цей параметричний варіант посідає проміжне місце в сімействі ML-KEM і надає дві важливі переваги. По-перше, рівень NIST 3 добре узгоджується з практикою довготривалого захисту облікових записів і секретів сесії. По-друге, розміри pk_{kem} та ct_{kem} хоча й істотно збільшують обсяг повідомлень порівняно з класичним OPAQUE, проте не роблять протокол непридатним для інтерактивного застосування. Таким чином, ML-KEM-768 у цьому дизайні є не “максимально потужним” і не “мінімально легким” варіантом, а параметром із збалансованим співвідношенням запасу безпеки та системних накладних витрат.

2.5 Нові підходи до постквантових РАКЕ (2023–2026)

У 2023–2026 роках у цій галузі виокремилося кілька головних дослідницьких ліній, які станом на 2026 рік визначають актуальний ландшафт постквантових РАКЕ та гібридних aРАКЕ-підходів.

КЕМ-базовані постквантові РАКЕ. Одна з найактивніших ліній робіт спирається на абстракцію КЕМ і прагне побудувати РАКЕ з мінімальними накладними витратами щодо базового постквантового примітива. Репрезентативним прикладом є СНІС [29], де автори одержують компактний решітковий РАКЕ з доведенням УС-безпеки та реалізаційною оцінкою. Такі результати демонструють, що чисто постквантовий РАКЕ уже вийшов за межі суто теоретичних побудов, однак типово не орієнтується на асиметричну клієнт-серверну модель ОРАКЕ.

Постквантові УС/QROM-конструкції. Окремий напрямок зосереджено на досягненні сильних композиційних гарантій безпеки. Робота [31] пропонує УС-безпечні РАКЕ для постквантового світу, включаючи QROM-варіанти на основі LWE. Ці результати важливі як теоретична опора, але вони не розв’язують безпосередньо задачу міграції вже існуючих ОРАКЕ-подібних систем, де ключовими є сумісність з реальною серверною моделлю експлуатації, мережевий формат повідомлень і відтворювані дослідницькі матеріали.

Решітково-орієнтовані OPRF-замінники та КЕМ-to-РАКЕ компілятори. Конструкції на основі задачі Learning With Errors (LWE) пропонуються як постквантові альтернативи Ristretto-OPRF, проте мають суттєво більший розмір сліпих елементів та знижену ефективність [28]. Водночас останні роботи вказують, що узагальнені КЕМ-to-РАКЕ підходи потребують дуже обережного поводження з ідеальним шифром, хешуванням у простір публічних ключів та інстанціюванням низькоентропійних секретів [29].

Ізогенні РАКЕ. Атаки Castryck–Decru (2022) [34] підірвали довіру до SIDH-базованих конструкцій. SIDH-базовані РАКЕ вважаються небезпечними.

Гібридний підхід як окремий напрямок досліджень. Новітні праці вже формалізують саму постановку гібридного РАКЕ. Зокрема, робота [30] пропонує РАКЕ-комбінатори з ефективними постквантовими інстанціюваннями, а [32] аналізує гібридний РАКЕ в УС-рамці через паралельну та послідовну композицію. Показово, що у 2025 році з’явилася й індивідуальна чернетка IETF із гібридного постквантового асиметричного РАКЕ для CFRG [33], що свідчить про перехід теми від суто академічних конструкцій до передстандартизаційної фази. На цьому тлі Hybrid PQ-ОРАКЕ позиціонується як реалізаційно-орієнтований крок у напрямі гібридного розширення ОРАКЕ з явною специфікацією мережевого формату, формальними моделями та відкритою реалізацією.

3 Постановка задачі

3.1 Формулювання проблеми та модель загроз

Нехай C (клієнт/ініціатор) та S (сервер/респондер) — дві сторони протоколу, де C володіє паролем pwd , а S зберігає реєстраційний запис res . Позначимо через $\mathbb{G}$ — групу Ristretto255 простого порядку q з генератором g .

Активи, що підлягають захисту:

- Пароль pwd ; статичні ключі sk_C, sk_S ; ефемерні ключі $e_C, e_S, sk_{\text{kem}}$;
- Реєстраційний запис $\text{rec} = (\text{envelope}, pk_C)$;
- Сесійний ключ K_s , майстер-ключ K_m , спільний секрет ss_{kem} .

Модель противника. Розглядаємо три класи:

- *Класичний $\mathcal{A}_C$* : поліноміально обмежений, активний «людина посередині», може компрометувати серверне сховище;
- *Квантовий $\mathcal{A}_Q$* : розв’язує DLP/ECDLP (алгоритм Шора), застосовує стратегію «збирай зараз — дешифруй пізніше»;
- *Композитний $\mathcal{A}_{CQ}$* : активний «людина посередині» із квантовим обчислювальним оракулом.

Вимоги до протоколу:

- R1** (ОРАQUE-властивості): таємність пароля, пряма секретність, взаємна автентифікація, стійкість до офлайн-перебирання;
- R2** (Постквантова стійкість): захист від стратегії «збирай зараз — дешифруй пізніше»;
- R3** (AND-інтерпретація): комбінатор ключового матеріалу має бути сумісним з AND-інтерпретацією в прийнятій моделі, тобто явне відновлення фінального ключа не повинно зводитися до ослаблення лише одного шару;
- R4** (Мінімальні накладні витрати): збереження 3 повідомлень та 1,5 раундів обміну;
- R5** (Реалізованість): кросплатформна реалізація, придатна до відтворення та подальшого інженерного розвитку.

3.2 Формальні визначення

Означення 1 (КЕМ). ($\text{KeyGen}, \text{Encaps}, \text{Decaps}$): $\text{KeyGen}() \rightarrow (pk, sk)$; $\text{Encaps}(pk) \rightarrow (ct, ss)$; $\text{Decaps}(sk, ct) \rightarrow ss$. *IND-CCA2 безпека: жоден поліноміально обмежений противник з оракулом декапсуляції не відрізняє реальний ss від випадкового.*

Означення 2 (Гібридний aPAKE у межах цієї роботи). *Протокол Π між $\mathcal{C}(\text{pwd})$ та $\mathcal{S}(\text{rec})$, у якому*

$$\text{IKM}_{\text{cl}} = dh_1 \| dh_2 \| dh_3 \| dh_4, \quad \text{IKM}_{\text{pq}} = ss_{\text{kem}},$$

а фінальний пре-ключ формується як

$$\text{PRK} = \text{HKDF-Extract}(\text{salt}_\tau, \text{IKM}_{\text{cl}} \| \text{IKM}_{\text{pq}}).$$

Подальший розділ аналізує, якою мірою така конструкція сумісна з AND-інтерпретацією безпеки в прийнятій моделі.

Означення 3 (Псевдовипадковість HKDF-Extract). Функцію *HKDF-Extract* на основі *HMAC-SHA-512* моделюємо як екстрактор: якщо ІКМ містить приховану обчислювальну ентропію відносно противника, тоді вихід *PRK* є обчислювально нерозрізнюваним від рівномірного за перевагою не більше ε .

Нотація: $\mathbb{G}$ — Ristretto255, $|\mathbb{G}| = q$; малі літери — скаляри; великі — точки кривої; $\parallel$ — конкатенація; $H(\cdot)$ — SHA-512; $\mathcal{K} = (K_s, K_m)$ — сесійний та майстер-ключ.

4 Опис запропонованого протоколу Hybrid PQ-OPRQUE

4.1 Архітектура та огляд

Гібридний PQ-OPRQUE є гібридним постквантовим розширенням OPRQUE [5]. Протокол зберігає властивість aPAKE (сервер не отримує доступу до пароля) та додає стійкість до стратегії «збирай зараз — дешифруй пізніше». Протокол має дві фази: *реєстрація* (одноразова фаза) та *автентифікація* (обмін із трьох повідомлень KE1–KE2–KE3). Надалі терміни «мережевий формат повідомлень» і «корисні дані» вживаються у значеннях, зафіксованих у Табл. 1.

Табл. 3. Криптографічні примітиви протоколу Hybrid PQ-OPRQUE

Компонент	Примітив	Реалізація	Рівень безпеки
Група OPRF	Ristretto255	curve25519-dalek	128 біт
Геш-функція	SHA-512	sha2	256 біт
KDF (витяг)	HKDF-Extract (HMAC-SHA-512)	hmac + sha2	256 біт
KDF (розш.)	HKDF-Expand (HMAC-SHA-512)	hmac + sha2	256 біт
MAC	HMAC-SHA-512	hmac + sha2	256 біт
KSF	Argon2id (MODERATE)	argon2	Адаптивний
AEAD	XSalsa20-Poly1305	crypto_secretbox	256 біт
KEM	ML-KEM-768 (FIPS 203)	ml-kem	NIST Рівень 3
Класичний обмін	4DH (Ristretto255)	curve25519-dalek	128 біт
Рівночасове порівняння	Побайтове без раннього виходу	subtle	—

Рисунок 1 робить наочним важливий практичний висновок: постквантовий шар не змінює суттєво логіку завершення автентифікації, але істотно збільшує транспортний бюджет перших двох повідомлень, тобто саме тих фаз, де відбувається передавання pk_{kem} та ct_{kem} .

Табл. 4. Розміри повідомлень автентифікації в корисних даних і мережевому форматі

Повідомлення	Класичні корисні дані	Гібридні корисні дані	Гібридний мережевий формат	Постквантові накладні витрати
KE1	88 байт	1272 байти	1273 байти	+1184 (pk_{kem})
KE2	288 байт	1376 байтів	1377 байтів	+1088 (ct_{kem})
KE3	64 байти	64 байти	65 байтів	0
Разом	440 байтів	2712 байтів	2715 байтів	+2272 (+516%)

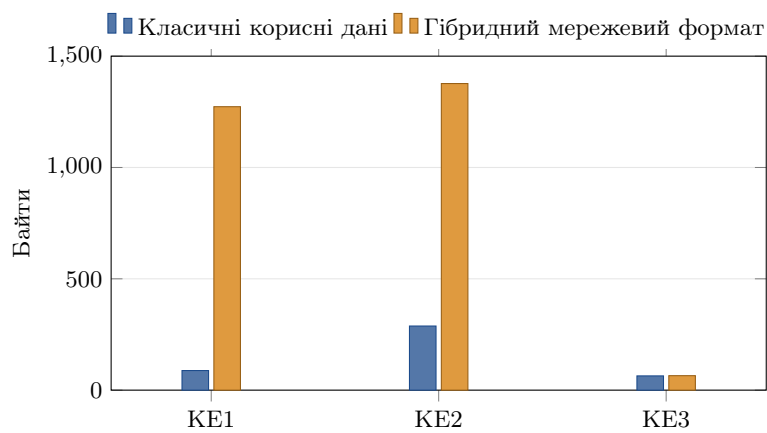


Рис. 1. Порівняння обсягу повідомлень автентифікації: додатковий мережевий обсяг зосереджено у повідомленнях KE1 та KE2, тоді як KE3 лишається майже незмінним.

4.2 Фаза реєстрації

Крок 1 ($\mathcal{C} \rightarrow \mathcal{S}$). Генерація статичної пари (sk_C, PK_C) ; засліплення в OPRF:

$$r \xleftarrow{\$} \mathbb{Z}_q^*, \quad B = r \cdot H'(L_{\text{opr}} \| 0x00 \| \text{pwd}) \quad (3)$$

RegistrationRequest = B (32 байти).

Крок 2 ($\mathcal{S} \rightarrow \mathcal{C}$). Виведення OPRF-ключа:

$$s_{\text{opr}} = \text{HMAC}(\sigma_{\text{opr}}, L_{\text{seed}})[0..31] \quad (4)$$

$$k_{\text{opr}} = \text{ScalarReduce}(\text{HMAC}(s_{\text{opr}}, L_{\text{key}} \| \text{acct} \| \text{ctr})) \quad (5)$$

де ctr — найменший лічильник, для якого отриманий скаляр ненульовий. Обчислення $Z = k_{\text{opr}} \cdot B$; ключ k_{opr} негайно знищується. Відповідь = $Z \| PK_S$ (64 байти).

Крок 3 ($\mathcal{C}$). Зняття засліплення в OPRF:

$$U = r^{-1} \cdot Z.$$

OPRF-вихід:

$$y_{\text{opr}} = H(L_{\text{opr}} \| 0x01 \| \text{pwd} \| U) \quad (6)$$

Вхід та сіль для KSF:

$$x_{\text{ksf}} = H(L_{\text{ksf}} \| y_{\text{opr}} \| \text{pwd}), \quad (7)$$

$$\text{salt}_{\text{ksf}} = H(L_{\text{salt}} \| y_{\text{opr}})[0..15]. \quad (8)$$

Тоді рандомізований пароль обчислюється як

$$\text{rwd} = \text{Argon2id}(x_{\text{ksf}}, \text{salt}_{\text{ksf}}; m = 256 \text{ MiB}, t = 3, p = 1) \quad (9)$$

Конверт запечатується за допомогою XSalsa20-Poly1305 і ключа, виведеного через HKDF; RegistrationRecord = Envelope $\| PK_C$ (168 байт корисних даних, 169 байт у мережевому форматі з урахуванням префікса версії).

4.3 Прив'язка ідентифікатора облікового запису, версії та контексту

На рівні реалізації протокол фіксує додатковий контекст, який у багатьох абстрактних описах OPAQUE лишається неявним. По-перше, всі повідомлення у мережевому форматі мають 1-байтовий префікс версії $v = 0x01$, який відокремлює корисні дані від повного формату передавання і забезпечує безпечне відхилення невідомих версій. По-друге, протокол оперує явним ідентифікатором облікового запису acct, який використовується не лише як ключ доступу до запису користувача, а й як криптографічно зв'язаний контекст.

Нехай

$$\eta = H(L_{\text{ctx}} \| \text{acct}) \quad (10)$$

Різні доменно-розділові мітки використано тут навмисно. Позначення $L_{\text{opr}}f$, L_{seed} , L_{key} , L_{kst} , L_{salt} і L_{r} зарезервовано для базових контекстів OPRF, KSF та транскрипту; L_{ctx} маркує окремо введenu прив'язку ідентифікатора облікового запису, а L_{comb} відокремлює гібридний комбінатор і похідні ключі. Тому номер версії в такій мітці слід читати як локальний ідентифікатор домену, а не як глобальний номер всієї схеми. Тоді asst впливає на протокол у двох точках:

1. через виведення OPRF-ключа, пов'язаного з конкретним обліковим записом, за формулою (5);
2. через включення η , визначеного в (10), до розширеного транскрипту (16), а отже і до гібридного комбінатора (17) та похідних ключів (18).

Таке зв'язування унеможливорює перенесення елементів мережевого формату між різними обліковими записами навіть за однакового пароля, а також робить опис реалізації точнішим порівняно з абстрактними специфікаціями, які залишають ідентифікатор користувача поза криптографічною частиною рукописання.

4.4 Фаза автентифікації та гібридний ключовий обмін

Генерація KE1 ($\mathcal{C} \rightarrow \mathcal{S}$)

$$e_C \xleftarrow{\$} \mathbb{Z}_q^*, \quad E_C = e_C \cdot g, \quad n_C \xleftarrow{\$} \{0, 1\}^{192}, \quad (11)$$

$$(pk_{\text{kem}}, sk_{\text{kem}}) \leftarrow \text{ML-KEM-768.KeyGen}(). \quad (12)$$

$$\text{KE1} = B \| E_C \| n_C \| pk_{\text{kem}} \quad (32 + 32 + 24 + 1184 = 1272 \text{ байти корисних даних}). \quad (13)$$

Повідомлення у мережевому форматі має вигляд $v \| \text{KE1}$ і займає 1273 байти.

Генерація KE2 ($\mathcal{S} \rightarrow \mathcal{C}$) Чотиристоронній Діффі–Геллман (4DH):

$$dh_1 = sk_S \cdot PK_C, \quad dh_2 = sk_S \cdot E_C, \quad dh_3 = e_S \cdot PK_C, \quad dh_4 = e_S \cdot E_C. \quad (14)$$

Інкапсуляція ML-KEM-768:

$$(ct_{\text{kem}}, ss_{\text{kem}}) \leftarrow \text{ML-KEM-768.Encaps}(pk_{\text{kem}}). \quad (15)$$

Розширений транскрипт (включає постквантові елементи):

$$\begin{aligned} \tau &= E_C \| E_S \| n_C \| n_S \| PK_C \| PK_S \| \text{CredResp} \| pk_{\text{kem}} \| ct_{\text{kem}} \| \eta \\ \tau_H &= H(L_\tau \| \tau) \end{aligned} \quad (16)$$

Гібридний комбінатор:

$$\begin{aligned} \text{combined_ikm} &= dh_1 \| dh_2 \| dh_3 \| dh_4 \| ss_{\text{kem}} \quad (128 + 32 = 160 \text{ байт}) \\ \text{salt} &= L_{\text{comb}} \| \tau_H \\ \text{PRK} &= \text{HKDF-Extract}(\text{salt}, \text{combined_ikm}) \end{aligned} \quad (17)$$

Деривація ключів. Нехай A_s , A_m , A_{macS} та A_{macC} позначають фіксовані мітки для сеансового ключа, майстер-ключа та двох ключів підтвердження:

$$\begin{aligned} K_s &= \text{HKDF-Expand}(\text{PRK}, A_s, 64) \\ K_m &= \text{HKDF-Expand}(\text{PRK}, A_m, 32) \\ K_{\text{mac}}^S &= \text{HKDF-Expand}(\text{PRK}, A_{\text{macS}}, 64) \\ K_{\text{mac}}^C &= \text{HKDF-Expand}(\text{PRK}, A_{\text{macC}}, 64) \end{aligned} \quad (18)$$

$$\text{KE2} = n_S \| E_S \| \text{CredResp} \quad (19)$$

$$\text{HMAC}(K_{\text{mac}}^S, \tau) \| ct_{\text{kem}} \quad (1376 \text{ байтів корисних даних}). \quad (20)$$

Повідомлення у мережевому форматі має вигляд $v \| \text{KE2}$ і займає 1377 байтів.

Генерація KE3 ($\mathcal{C} \rightarrow \mathcal{S}$)

1. OPRF-фіналізація, відкриття конверта, відновлення (PK_S, sk_C, PK_C) ;
2. Дзеркальний 4DH: $dh_1 = sk_C \cdot PK_S$, $dh_2 = e_C \cdot PK_S$, $dh_3 = sk_C \cdot E_S$, $dh_4 = e_C \cdot E_S$ (додаткове зв'язування ефемерних компонент на рівні 4DH-інтуїції);
3. Декапсуляція: $ss_{\text{kem}} = \text{ML-KEM-768.Decaps}(sk_{\text{kem}}, ct_{\text{kem}})$; sk_{kem} негайно знищується;
4. Ідентична деривація PRK; верифікація $\text{HMAC}(K_{\text{mac}}^S, \tau)$ рівночасовою функцією побайтового порівняння без раннього виходу;
5. $\text{KE3} = \text{HMAC}(K_{\text{mac}}^C, \tau)$ (64 байти корисних даних, 65 байтів із префіксом версії).

Завершення на стороні сервера Верифікація KE3 рівночасовою функцією порівняння. При успіху — пара (K_s, K_m) стає доступною обом сторонам, підтверджуючи взаємну автентифікацію. При відмові — всі ключові матеріали негайно знищуються через безпечне затирання.

4.5 Включення постквантових елементів у транскрипт

Включення pk_{kem} та ct_{kem} у транскрипт є **криптографічно необхідним**: воно *криптографічно зв'язує* постквантовий обмін з класичним. Без цього зв'язування противник типу «людина посередині» може замінити pk_{kem} власним ключем на рівні ML-KEM. Формально це зв'язування зафіксовано у розширеному транскрипті (16) та в гібридному комбінаторі (17). Окреме включення хешу контексту облікового запису η додатково унеможливорює перенесення валідного транскрипту між різними користувачами або повторне використання повідомлень автентифікації для іншого облікового запису асст. Отже, транскрипт у цій роботі виконує дві взаємопов'язані функції: він зв'язує класичний і постквантовий шари між собою та одночасно прив'язує їх до конкретного облікового запису й версії мережевого формату.

5 Аналіз безпеки

5.1 Формальний аналіз властивостей безпеки

Сценарій офлайн-перебирання за фіксованою межею довіри. У прийнятій моделі загроз нехай противник отримав пасивне серверне сховище гес і спостережувані транскрипти, але не `opr_f_seed`. Тоді він не може перевіряти словникові кандидати офлайн, окрім як із нехтовно малою перевагою, зумовленою порушенням забутливості OPRF або стійкості конверта. Якщо ж `opr_f_seed` скомпрометовано, задача зводиться до словникового пошуку з питомою вартістю одного припущення, що домінується Argon2id. Це формулювання має статус обмеженого безпекового твердження для чітко визначеної межі довіри, а не універсального твердження для всіх реалізацій OPAQUE.

Доведення (ескіз). **Випадок 1: `opr_f_seed` не скомпрометовано.** Без OPRF-ключа, пов'язаного з конкретним обліковим записом, противник не може обчислити y_{opr} за (6), а отже і відтворити $x_{\text{ksf}}, \text{salt}_{\text{ksf}}$ та pwd за (9). Тому запис конверта не дає ефективного офлайн-оракула перевірки пароля. Заміна OPRF-виходу випадковим значенням дає

$$|\Pr[S_1] - \Pr[S_0]| \leq \text{Adv}_{\text{OPRF}}^{\text{obliv}} \leq \text{Adv}_{\text{Ristretto255}}^{\text{CDH}}.$$

Гра 1 → Гра 2: замінюємо конверт шифруванням випадкового рядка (IND-CPA XSalsa20-Poly1305):

$$|\Pr[S_2] - \Pr[S_1]| \leq \text{Adv}_{\text{XSalsa20}}^{\text{IND-CPA}}.$$

Наслідок. За відсутності компрометації `opr_f_seed` найкраща стратегія зводиться до онлайн-вгадувань, тому

$$\text{Adv}^{\text{dict}} \leq \text{Adv}_{\text{Ristretto255}}^{\text{CDH}} + \text{Adv}_{\text{XSalsa20}}^{\text{IND-CPA}} + \frac{q_{\text{on}}}{|\mathcal{D}|}.$$

Випадок 2: `opr_f_seed` скомпрометовано. Тоді кожне словникове припущення pwd' може бути перевірене офлайн через обчислення y'_{opr} , далі $x'_{\text{ksf}}, \text{salt}'_{\text{ksf}}$ і одну спробу відкриття конверта. Отже вартість одного припущення асимптотично та практично домінується Argon2id, тобто безпосередньо процедурою (9):

$$T_{\text{guess}} \approx T_{\text{Argon2id}}, \quad C_{\text{offline}} \approx |\mathcal{D}| \cdot T_{\text{guess}}. \quad \blacksquare$$

Теорема (Пряма секретність). *Компрометація довготривалих ключів sk_C, sk_S після завершення сесії не дозволяє відновити K_s , за умови складності CDH та IND-CCA безпеки ML-KEM-768.*

Доведення (ескіз). Після компрометації відомо dh_1 . Але $dh_2 = sk_S \cdot E_C$ потребує ефемерного e_C (знищено); $dh_3 = e_S \cdot PK_C$ — ефемерного e_S (знищено). Аналогічно, ss_{kem} захищений IND-CCA ML-KEM-768: sk_{kem} знищено після декапсуляції.

$$\text{Adv}^{\text{FS}} \leq \text{Adv}_{\text{CDH}} + \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA}}. \quad \blacksquare$$

Теорема (Взаємна автентифікація). Ймовірність підробки MAC є нехтовно малою за умови PRF-стійкості HMAC-SHA-512:

$$\text{Adv}^{\text{auth}} \leq \text{Adv}_{\text{HMAC}}^{\text{PRF}} + q_s/2^{512}. \quad \blacksquare$$

Інтерпретаційне твердження про AND-властивість гібридного комбінатора. Нехай

$$\text{IKM}_{\text{cl}} = dh_1 \| dh_2 \| dh_3 \| dh_4, \quad \text{IKM}_{\text{pq}} = ss_{\text{kem}}.$$

Якщо для фіксованого транскрипту τ хоча б одне з джерел IKM_{cl} або IKM_{pq} залишається обчислювально нерозрізняваним від рівномірного, тоді

$$\text{PRK} = \text{HKDF-Extract}(\text{salt}_{\tau}, \text{IKM}_{\text{cl}} \| \text{IKM}_{\text{pq}})$$

може розглядатися як псевдовипадковий у межах стандартної екстракторної інтерпретації HKDF-Extract. Операційно це підтримує таку AND-інтерпретацію: для явного відновлення реального сеансового ключа з транскрипту противнику потрібно скомпрометувати *обидва* джерела. Отже, йдеться не про завершене обчислювальне доведення комбінатора, а про вмотивовану екстракторну інтерпретацію, сумісну з прийнятою моделлю.

Доведення (ескіз). Нехай S — те джерело серед $\{\text{IKM}_{\text{cl}}, \text{IKM}_{\text{pq}}\}$, яке залишається псевдовипадковим відносно зафіксованого транскрипту τ , а X — інше джерело. Тоді $\text{IKM}_{\text{cl}} \| \text{IKM}_{\text{pq}}$ можна подати як $S \| X$. Стандартна екстракторна властивість HMAC-базованого HKDF-Extract [23] підказує, що якщо S є обчислювально нерозрізняваним від рівномірного, то й PRK слід очікувати псевдовипадковим навіть за довільного X . Звідси випливає груба верхня оцінка: порушення нерозрізненості фінального ключа можливе або через злам того джерела, яке “вижило”, або через злам екстрактора:

$$\text{Adv}^{\text{hybrid}} \leq \min(\text{Adv}_{\text{CDH}}^{\text{Ristretto255}}, \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA}}) + \text{Adv}_{\text{HKDF}}^{\text{ext}}. \quad \blacksquare$$

Для геометричної інтерпретації наведеної AND-інтерпретації введемо нормалізовані координати

$$x = \text{Adv}_{\text{CDH}}^{\text{Ristretto255}}, \quad y = \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA}},$$

і розглянемо поверхню

$$z = \min(x, y),$$

яка відображає головну частину верхньої межі гібридної переваги без адитивного малого доданка $\text{Adv}_{\text{HKDF}}^{\text{ext}}$. За такої побудови діагональ $x = y$ задає лінію рівноваги між двома шарами, а ізолінії $z = c$ на площині $z = 0$ показують, за яких комбінацій ослаблення класичного і постквантового компонентів досягається однакова гібридна перевага противника.

Рисунок 2 задає структурне геометричне тлумачення гібридизації: діагональ $x = y$ відокремлює режими домінування класичного та постквантового шарів, а ізолінії на площині $z = 0$ показують, що однаковий рівень гібридної переваги виникає лише за одночасного ослаблення обох координат.

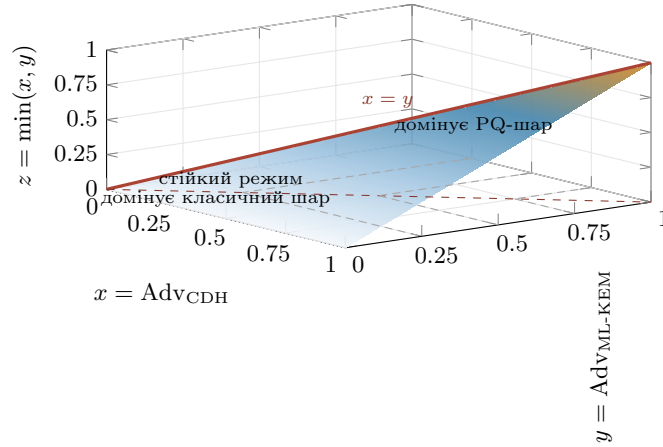


Рис. 2. 3D-геометрія AND-інтерпретації: поверхня $z = \min(x, y)$, діагональ $x = y$ та ізолінії рівнів на площині $z = 0$.

5.2 Стійкість до відомих атак

Атаки офлайн-перебирання за словником. Захист слід читати в межах компрометації бази даних без компрометації *opr_f_seed*. За цієї умови працюють три незалежні шари: (1) OPRF — без серверного ключа k_{opr} противник не може обчислити rwd ; (2) Argon2id із параметрами MODERATE (256 MiB, 3 ітерації) — на вимірювальній платформі одна спроба коштує приблизно $T_{\text{guess}} \approx 0,5$ с, тобто послідовний повний перебір словника масштабується як $C_{\text{offline}} \approx |\mathcal{D}| \cdot T_{\text{guess}}$; (3) XSalsa20-Poly1305 — верифікація кандидата потребує успішного автентифікованого розшифрування. Якщо ж *opr_f_seed* скомпрометовано, це твердження не переноситься автоматично на нову модель загроз і потребує окремого аналізу.

Атака «людина посередині». Транскрипт τ включає всі відкриті елементи, зокрема pk_{kem} та ct_{kem} . Модифікація будь-якого поля призводить до незбіжності MAC.

Атака повторного відтворення. Ефемерні одноразові числа (192 біти) та ефемерні ключі генеруються заново для кожної сесії. Ймовірність колізії нонсів: 2^{-192} .

Атака «збирай зараз — дешифруй пізніше». Навіть при відновленні $dh_1, \dots, dh_4$ алгоритмом Шора, секрет ss_{kem} залишається захищеним ML-KEM-768 (Module-LWE, еквівалент AES-192).

Атака на компрометований ключ (КСІ). Компрометація sk_S не надає доступу до $dh_2 = sk_S \cdot E_C$ після закінчення сесії (залежить від знищеного e_C) та до ss_{kem} (залежить від знищеного sk_{kem}).

Часові бічні канали. Усі порівняння MAC виконуються рівночасовим побайтовим порівнянням без раннього виходу. Скалярне множення на Ristretto255 та NTT в ML-KEM реалізовано в рівночасовий спосіб.

5.3 Формальна верифікація

Огляд верифікації Протокол досліджено двома незалежними символьними інструментами в моделі Dolev–Yao: ProVerif 2.05 та Tamarin Prover 1.10.0. Важливо, однак, відразу зафіксувати інтерпретацію результатів. У цій роботі символьна верифікація розглядається як *доказова база* для структурних властивостей протоколу, а не як рядок-у-рядок доведення коректності Rust/FFI-реалізації. ProVerif використовується у двох окремих моделях для секретності та автентифікації; Tamarin застосовується до верифікованої сурогатної 4DH-моделі. Тому всі підсумкові твердження мають читатися разом із межами моделі та експериментальними матеріалами [24,25].

Табл. 5. Підсумок формальної доказової бази

#	Властивість	ProVerif	Tamarin (сурогатна 4DH модель)	Rust-тести
P1	Секретність сесійного ключа	підтверджено	підтверджено (27 кр.)	4 тести
P2	Секретність пароля на дроті	підтверджено	підтверджено (3 кр.)	6 тестів
P3	Класична пряма секретність	—	підтверджено (119 кр.)	3 тести
P4	Постквантова пряма секретність	—	аргументується через P6 у межах моделі	3 тести
P5a	Автентифікація ініціатора	підтверджено	підтверджено (32 кр.)	8 тестів
P5b	Автентифікація респондера	підтверджено	підтверджено (17 кр.)	—
P5c	Ін'єктивна взаємна автентифікація	підтверджено	випливає з P5a/P5b	—
P6	AND-модель гібридної безпеки	—	підтримано в сурогатній моделі (29 кр.)	4 тести
P7	Стійкість до офлайн-перебору	—	підтримано для моделі БД без <code>prf_seed</code> (4 кр.)	6 тестів
—	Коректність завершення	—	підтверджено (16 кр.)	5 тестів
Разом		5/5 запитів	8/8 лем	155 пройдено, 1 пропущено

Таблиця 5 навмисно поєднує символьні й реалізаційні матеріали. Це не означає взаємозамінність моделей; радше, йдеться про ієрархію доказовості. ProVerif краще виявляє помилки в логіці повідомлень і кореспондентні властивості у спрощеному обчислювальному світі необмежених сесій, тоді як Tamarin дає змогу формалізувати станові властивості на кшталт прямої секретності та AND-моделі. Rust-тести, своєю чергою, перевіряють, що ці властивості не втрачаються в конкретній реалізації для широкого набору криптографічних значень.

ProVerif 2.05 Інструмент: ProVerif 2.05 (OCaml 5.4.0), macOS Darwin 25.2.0. Використано дві взаємодоповнювальні моделі: базову модель секретності та окрему модель автентифікації, архівовані у пакеті дослідницьких матеріалів. Поділ на дві моделі є не технічною дрібницею, а методологічним рішенням: одна й та сама насичена модель не давала стабільної збіжності для всіх запитів одночасно. Тому результати ProVerif потрібно читати як сукупність двох сумісних, але різних поглядів на протокол.

Найбільш інформативним для властивості взаємної автентифікації є запит P5c (ін'єктивна взаємна відповідність): він стверджує, що кожному успішному завершенню на стороні респондера відповідає окреме узгоджене завершення на стороні ініціатора для тієї самої пари сторін і того самого

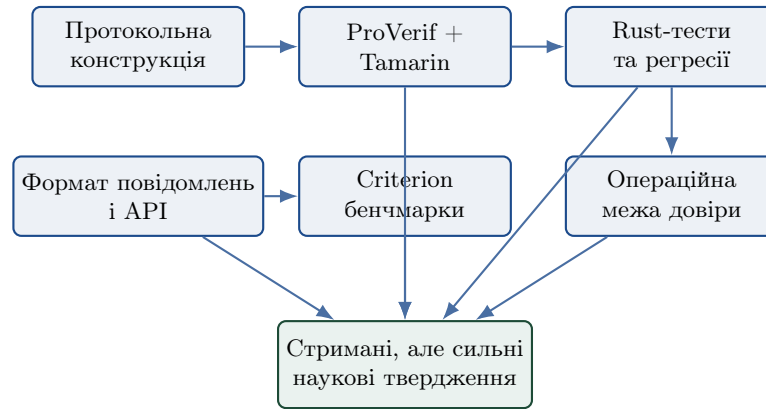


Рис. 3. Структура доказової бази Hybrid PQ-OPAQUE: підсумкові висновки спираються на узгодження моделі, коду, вимірювань та експлуатаційних меж, а не на один ізольований матеріал.

сеансового ключа. Позитивний результат перевірки означає, що завершення сесії на стороні респондера не може бути пояснене повторним програванням одного й того ж успішного трасування для кількох клієнтських завершень. Водночас цей результат не слід тлумачити як обчислювальне доведення всієї реалізації: в моделі відсутні бічні канали, варіативність формату помилок, витоки, пов'язані з часовими характеристиками, та низка мережевих деталей, які залишаються предметом реалізаційних тестів.

Tamarin Prover 1.10.0 Інструмент: Tamarin 1.10.0 (Maude 3.4). Верифіковано сурогатну модель гібридного комбінатора; архівований журнал повного доведення фіксує загальний час обробки **22,83 секунди** для всіх восьми лем.

Суттєво, що верифікована Tamarin-модель не використовує вбудовану рівняльну теорію Діффі-Геллмана для повної 4DH-конструкції. Натомість вона замінює 4DH на абстрактний секрет $\xi_{4dh} = h(\langle sk_C, sk_S, e_C, e_S \rangle)$ й перевіряє, які події компрометації потрібні противнику для виведення сесійного ключа. Це істотно полегшує автоматизоване доведення, але саме тому її результати слід трактувати як сурогатну символічну аргументацію, а не як формальний доказ конкретної реалізації кожної операції Ristretto255.

Центральною для подальшої інтерпретації є лема P6 (AND-модель): вона стверджує, що з факту встановлення сеансового ключа та відсутності розкриття ефемерних секретів ініціатора і респондера випливає невивідність цього ключа для противника. Машинна перевірка цієї леми завершується позитивно за 29 кроків.

Лема допускає компрометацію довгоживучих ключів, але забороняє розкриття ефемерних. Навіть знаючи довгоживучі секрети сторін, противник не може відновити гібридний ключовий матеріал без одночасного доступу до ефемерних компонент класичного та постквантового шарів. У межах цієї

Табл. 6. Підтверджені леми Tamagiri для сурогатної 4DH-моделі

Лема	Кроки Ключова властивість
Секретність сеансового ключа (P1)	27 Без подій корупції противник не може вивести сесійний ключ
Секретність пароля (P2)	3 Пароль не потрапляє до зовнішньо спостережуваних подій моделі
Пряма секретність (P3)	119 Постсесійна компрометація довгоживучих ключів не розкриває ефемерні секрети
Автентичність ініціатора (P5a)	32 Успішне завершення клієнтського кроку вимагає попереднього запуску респондера
Автентичність респондера (P5b)	17 Успішне завершення на стороні сервера вимагає валідного КЕЗ
AND-інтерпретація комбінатора (P6)	29 Без компрометації ефемерних секретів не відновлюються одночасно 4DH і KEM-компоненти
Стійкість до офлайн-перебору в моделі БД (P7)	4 Компрометація бази розкриває запис, але не OPRF-ключ
Завершуваність (коректність)	16 Існує трасування з успішним завершенням протоколу

сурогатної моделі це підтримує інтерпретацію AND-моделі: для виведення сесійного ключа потрібне одночасне ослаблення *обох* шарів. Саме ця лема дає лише опосередковану аргументацію на користь P4; вона не замінює окремої формалізації постквантової прямої секретності.

Межі інтерпретації результатів Щоб уникнути надмірної інтерпретації формальних результатів, зафіксуємо чотири ключові обмеження.

1. **Сурогатне подання 4DH.** Верифікована модель Tamagiri абстрагує 4DH-компонент до однієї функції знання. Такий крок полегшує доведення, але не замінює аналіз конкретних алгебраїчних властивостей групових операцій.
2. **Розділені моделі ProVerif.** Секретність і автентифікація досліджуються не в одній універсальній моделі, а в двох окремих матеріалах. Отже, результат 5/5 слід трактувати як сукупність двох узгоджених моделей, а не як монолітне доведення.
3. **Межа застосовності тверджень про офлайн-стійкість.** Лема P7 і відповідні Rust-тести покривають сценарій компрометації бази даних *без* компрометації σ_{orpf} . Якщо σ_{orpf} розкрито, властивість офлайн-стійкості потребує окремого аналізу і не повинна автоматично переноситися з моделі.
4. **Розрив між моделлю та реалізацією.** Символьна верифікація не охоплює бічні канали, поведінку компілятора, властивості виділення пам'яті, API-помилки FFI чи вразливості зовнішніх крейтів. Саме тому результати формальної верифікації в роботі доповнюються тестами й еталонними вимірюваннями, а не підміняють їх.

6 Реалізація та експериментальна оцінка

6.1 Архітектура Rust-реалізації

Протокол реалізовано мовою **Rust 1.93.1** у вигляді багатокрейтного простору проєктів. Вибір Rust обумовлений: гарантіями безпеки пам'яті на рівні системи типів (відсутність нульових показників, статичний контроль часу життя посилань, механізм перевірки запозичень); вимогою повної відсутності небезпечного коду в криптографічному ядрі; а також механізмами безпечного затирання секретів у пам'яті.

Табл. 7. Метрики вихідного коду простору проєктів

Компонент	Призначення	РВК	Основні залежності
Криптографічне ядро	Примітиви, деривація ключів і серіалізація протоколу	1509	Ristretto255, ML-KEM, Argon2id
Клієнтський контур	Логіка ініціатора та клієнтські фази протоколу	899	криптографічне ядро
Серверний контур	Логіка респондера та завершення сесії	907	криптографічне ядро
Шар міжмовної взаємодії	FFI-інтерфейс і зовнішній виклик протоколу	2020	клієнтський і серверний контури
Разом (основний код)		5335	
Тести		3961	властивісні та регресійні сценарії
Еталонні вимірювання		1460	Criterion
Формальні моделі		1806	Tamarin, ProVerif

6.2 Безпека пам'яті та затирання секретів

Для криптографічної системи визначальним є не лише вибір примітивів, а й дисципліна поводження із секретами в адресному просторі процесу. У досліджуваній реалізації криптографічне ядро та обидва протокольні контури компілюються за політикою повної відсутності небезпечного коду, тоді як операції, що вимагають низькорівневої роботи з показниками, винесено на вузьку FFI-межу. Таке архітектурне розмежування не підмінює формального аналізу реалізації, проте істотно звужує простір дефектів керування пам'яттю: повторного звернення до звільнених ділянок, подвійного звільнення, втрати коректного володіння буфером і порушення узгодженості його меж.

Не менш важливим є контроль життєвого циклу секретів. Реалізація систематично застосовує автоматичне затирання під час виведення об'єктів

з ужитку та спеціальні обгортки для тимчасових значень, завдяки чому чутливі проміжні величини існують у пам'яті лише протягом мінімально необхідного інтервалу. Це не усуває всіх можливих каналів витoku, але помітно зменшує післякомпрометаційний залишок секретних даних у дампах пам'яті, аварійних журналах і повторно використаних буферах. Зокрема, затираються:

- пароль користувача та скаляр заплінення OPRF після фіналізації OPRF;
- ефемерний секрет ML-KEM після декапсуляції;
- класичний 4DH-матеріал, транскрипційний хеш і PRK після деривації похідних ключів;
- контекстний хеш `asct` після завершення KE2/KE3;
- станів структури ініціатора й респондера при перериванні або будь-якому завершенні з безпечним відхиленням.

6.3 Тестова та відтворювана база

Доказова база реалізації побудована за принципом трасування між безпековими твердженнями, символьними моделями та виконуваними матеріалами. У поточній ревізії простору проєктів відтворюється 155 пройдених тестів і 1 свідомо пропущений повільний сценарій граничної регресії; до пакета входять модульні, інтеграційні, властивісні та регресійні тести для протокольного життєвого циклу, мережевого формату, FFI-контракту, OPRF/KEM-коректності та безпечного відхилення помилкових станів.

Методологічно важливим є рознесення доказовості по трьох рівнях: (1) Rust-тести й регресії реалізації; (2) еталонні вимірювання на Criterion 0.5.1 [27]; (3) символьні моделі ProVerif і Tamarin з архівованими журналами. Така організація зменшує ризик підміни понять: формальні інструменти перевіряють абстрактну логіку протоколу, тоді як тести реалізації виявляють помилки серіалізації, версійності, життєвого циклу стану та перевірки меж вхідних даних, які принципово не покриваються символьною моделлю.

Еталонні вимірювання виконано на Apple M1 Pro (8 ВП + 2 ЕЕ ядра, 16 ГБ LPDDR5, macOS 26.2, Rust 1.93.1) у детермінованому однопотоковому оптимізованому режимі компіляції. Criterion застосовує бутстрап-оцінювання середнього та 95%-го довірчого інтервалу; отже, наведені нижче числа слід читати як відтворювані оцінки для цієї платформи, а не як універсальні константи для будь-якого середовища. Мінімальний зовнішній аудит зводиться до відтворення повного набору тестів, еталонних вимірювань і формальних моделей. Саме така багатопарова відтворюваність є для цієї роботи важливішою, ніж каталогізація кожного допоміжного файла в основному тексті статті.

6.4 Еталонні вимірювання криптографічних примітивів

МікрОВимірювання показують три стійкі співвідношення. По-перше, повний раунд ML-KEM-768 (122,01 мкс) і 4DH (≈ 164 мкс) лежать в одному порядку

Табл. 8. Еталонні вимірювання криптографічних примітивів

Примітив	Операція	$\hat{\mu}$	95% ДІ
Ristretto255	Генерація ключової пари	16,74 мкс	[16,03; 17,84]
Ristretto255	Одиничне DH	46,41 мкс	[45,94; 46,98]
Ristretto255	3DH (еталон)	119,04 мкс	[117,10; 122,14]
Ristretto255	4DH (протокол)	≈ 164 мкс	$[\approx 162; \approx 167]$
ML-KEM-768	Генерація ключової пари	41,05 мкс	[40,69; 41,68]
ML-KEM-768	Інкапсуляція	33,62 мкс	[32,89; 34,95]
ML-KEM-768	Декапсуляція	38,55 мкс	[37,65; 40,11]
ML-KEM-768	Повний раунд	122,01 мкс	[119,32; 126,96]
OPRF	Засліплення	56,16 мкс	[54,37; 59,36]
OPRF	Обчислення сервера	47,59 мкс	[44,97; 52,45]
OPRF	Фіналізація	65,68 мкс	[64,17; 67,89]
HKDF	Витяг	1,32 мкс	[1,312; 1,319]
HKDF	Розширення (64 байти)	1,21 мкс	[1,181; 1,245]
HMAC-SHA-512	256 байт	1,61 мкс	[1,596; 1,641]
XSalsa20-Poly1305	Шифрування 96 байт	440,79 нс	[430,20; 459,46]
XSalsa20-Poly1305	Розшифрування 96 байт	613,42 нс	[594,15; 636,12]
Argon2id	MODERATE	510,86 мс	[490,31; 533,80]
Гібридний комбінатор	HKDF-Extract (160 байт)	1,48 мкс	[1,453; 1,508]

величини, тож постквантовий шар не змінює класу обчислювальної складності протоколу. По-друге, Argon2id (510,86 мс в ізолюваному вимірюванні) домінує над усіма іншими компонентами й визначає сприйману затримку автентифікації. По-третє, процедура гібридної екстракції ключового матеріалу (1,48 мкс) є практично безвартісною на тлі KSF і не становить окремого вузького місця.

6.5 Еталонні вимірювання протокольного рівня

Табл. 9. Еталонні вимірювання протокольних сценаріїв

Фаза	Сценарій вимірювання	$\hat{\mu}$	95% ДІ	Домінуючий компонент
Реєстрація	Формування запиту реєстрації	72,46 мкс	[72,15; 72,77]	Засліплення OPRF
Реєстрація	Формування відповіді сервера	45,92 мкс	[45,72; 46,16]	Обчислення OPRF
Реєстрація	Завершення реєстрації	479,58 мс	[472,11; 487,75]	Argon2id
Автентифікація	Формування KE1	118,83 мкс	[116,59; 121,76]	OPRF + генерація ключів ML-KEM
Автентифікація	Формування KE2	297,03 мкс	[294,81; 299,69]	4DH + інкапсуляція ML-KEM
Автентифікація	Формування KE3 на стороні ініціатора	492,34 мс	[478,95; 509,96]	Argon2id + декапсуляція ML-KEM
Автентифікація	Завершальна перевірка респондера	1,24 мкс	[1,174; 1,323]	Перевірка MAC
Повний	Наскрізний цикл автентифікації	481,43 мс	[471,73; 495,25]	Argon2id

Числа в Табл. 9 не є адитивними: ізольоване формування KE3 і повний сценарій автентифікації вимірювалися окремими еталонними прогонами з різним контуром підготовки стану. Тому середнє для повного циклу може бути трохи нижчим за середнє для ізольованої фази, тоді як 95%-і довірчі інтервали істотно перекриваються. Для цієї роботи принциповими є не пофазові суми, а порядки величин і домінуючі компоненти: серверна генерація KE2 залишається підмілісекундною операцією, а основний часовий внесок дає Argon2id.

6.6 Ключові кількісні висновки та реалізаційні наслідки

Ізольований серверний профіль показує, що криптографічне ядро респондера залишається достатньо легким для практичного розгортання: ізольоване формування KE2 становить 254,26 мкс, а завершальна перевірка респондера — лише 760,82 нс. Це дає теоретичну верхню межу близько $3,92 \times 10^3$ автентифікацій за секунду на ядро для криптографічно обмеженого сервера без урахування доступу до БД, телеметрії та бізнес-логіки.

Для повного AKE без KSF постквантовий компонент додає 159,3 мкс (+30,1%) процесорного часу, однак на тлі Argon2id цей надлишок зменшується приблизно до 0,03% типового наскрізного сценарію. Головний практичний компроміс пов'язаний не з CPU, а з мережевим обсягом: повний рукописистий обмін становить 2715 байт у мережевому форматі, тобто на 2272 байти більше за класичний варіант при незмінній кількості раундів.

Порівняльне твердження щодо класичного OPAQUE. Нехай $R_{\text{orp}}, C_{\text{orp}}, W_{\text{orp}}$ позначають відповідно раундову, обчислювальну та комунікаційну складність канонічного 3DH-OPAQUE без KSF, а $R_{\text{hyb}}, C_{\text{hyb}}, W_{\text{hyb}}$ — відповідні величини для Hybrid PQ-OPAQUE. Тоді

$$\begin{aligned} R_{\text{hyb}} &= R_{\text{orp}} = 3 \text{ повідомлення} = 1,5 \text{ раунду}, \\ C_{\text{hyb}} &= C_{\text{orp}} + C_{1\text{DH}} + C_{\text{кем}} + O(1), \\ W_{\text{hyb}} &= W_{\text{orp}} + \Delta W, \quad \Delta W = 2272 \text{ байти}. \end{aligned}$$

На еталонній платформі це відповідає виміряному приросту $C_{1\text{DH}} + C_{\text{кем}} \approx 159,3$ мкс без KSF. Отже, порівняно з відомим результатом класичного OPAQUE складність для чесних сторін зростає лише адитивно й лишається фіксовано-раундовою, тоді як у прийнятій моделі умова явної компрометації фінального ключового матеріалу посилюється: вона більше не зводиться до ослаблення суто класичного внеску, а інтерпретується як потреба одночасного нівелювання класичного та постквантового шарів.

7 Обговорення результатів

7.1 Інтерпретація формальної та експериментальної бази

У межах заявленої моделі результати підтримують усі п'ять вихідних вимог, але з різною силою. Класичні цілі OPAQUE-подібного aPAKE, включення

Табл. 10. Порівняння Hybrid PQ-OPAQUE з канонічним 3DH-OPAQUE

Аспект	3DH-OPAQUE	Hybrid PQ-OPAQUE	Інтерпретація
Раундова складність	3 повідомлення, 1,5 раунду	3 повідомлення, 1,5 раунду	Протокольна взаємодія не ускладнюється
Обчислювальна складність чесних сторін	Базовий 3DH-контур	+1 додатковий DH, + KEM, $+O(1)$	Приріст має адитивний, а не структурний характер
Комунікаційна складність	Базовий рюкостискальний обсяг	+2272 байти у мережевому форматі	Основний практичний компроміс зміщується в транспорт
Умова компрометації ключового матеріалу	Ослаблення класичного внеску	Однчасне нівелювання класичного і PQ-шару	Атакувальна умова стає структурно жорсткішою у прийнятій моделі

постквантового компонента до транскрипту й схеми виведення ключів, а також практична реалізованість конструкції підтверджено поєднанням символічних моделей, тестів і вимірювань. Натомість AND-властивість слід і далі читати саме як інтерпретацію, сумісну з прийнятим комбінатором і підкріплену сурогатною Tamagiri-моделлю, а не як завершене обчислювальне доведення для всіх постановок.

Головним формальним результатом є не окремий запуск ProVerif чи Tamagiri, а їх узгоджене читання разом із поведінкою реалізації. ProVerif дає кращу опору для секретності та відповідності, тоді як Tamagiri дозволяє сформулювати станові твердження на кшталт прямої секретності та інтерпретації гібридного комбінатора. Rust-тести, своєю чергою, закривають той клас похибок, який відсутній у символічних моделях: серіалізацію, життєвий цикл стану, перевірку меж вхідних даних і поведінку FFI-контракту.

7.2 Продуктивність, параметри KSF та межа довіри

Практичне читання вимірювань є однозначним: домінуючою складовою латентності залишається Argon2id, тоді як ML-KEM-768 і 4DH формують лише підмілісекундний криптографічний шар. Отже, ключовий операційний вибір під час розгортання стосується не питання “чи дорогий ML-KEM-768?”, а питання “який профіль KSF є прийнятним для конкретної групи користувачів і пристроїв?”. Для веб- та B2B-сценаріїв поточний профіль виглядає практично придатним; для мобільних або крайових середовищ може знадобитися окреме налаштування KSF і жорсткіші механізми обмеження частоти запитів.

Окремо слід підкреслити межу довіри до σ_{orpf} . Безпеківі твердження про стійкість до офлайн-перебирання коректні лише для сценарію компрометації бази даних *без* компрометації цього секрету. Тому σ_{orpf} має захищатися як кореневий криптографічний секрет сервісу: із відокремленим сховищем, рознесенням доступів, мінімізацією часу перебування в пам’яті та ретельною політикою ротації. У цьому сенсі наукова новизна схеми невіддільна від реалістичної моделі розгортання.

Перевагою міграції є те, що постквантовий компонент залишається ефемерним і не вимагає збільшення реєстраційного запису. Перехід зосереджується на прикладній логіці автентифікації, узгодженні версії та контекстному зв'язуванні *asst*. Водночас зростання мережевого формату до 2715 байт робить транспортне середовище важливішим, ніж у класичному OPAQUE: для TCP/QUIC це переважно питання буферів, а для датаграмних сценаріїв — ще й питання фрагментації та MTU.

7.3 Міграція, сумісність та операційна придатність

З практичного погляду гібридизація є цінною лише тоді, коли її можна впровадити без одночасного переоформлення всієї ідентифікаційної інфраструктури. У цьому сенсі обрана конструкція має дві важливі властивості. По-перше, реєстраційний запис не розростається за рахунок довгоживучого постквантового матеріалу, оскільки ML-KEM використовується лише в ефемерному контурі автентифікації. По-друге, перехід можна реалізовувати поетапно через явне версіонування мережевого формату й контекстне зв'язування *asst*, не руйнуючи вже наявний користувацький стан. Для операторів це означає, що міграція є радше завданням керованого rollout'у, ніж повного перевипуску реєстраційних даних.

Поетапний сценарій розгортання природно складається з трьох фаз. На першій фазі сервер приймає обидві версії протоколу, але пріоритизує класичний контур для зворотної сумісності й одночасно збирає телеметрію про типи клієнтів, частоту помилок парсингу та реальне мережеве навантаження. На другій фазі гібридна версія вмикається для нових сесій або для визначених груп користувачів, тоді як стара схема лишається запасним шляхом відновлення. Лише на третій фазі, коли стабільність мережевого формату, параметрів KSF і навантажувального профілю вже підтверджено експлуатацією, класичний режим може бути виведений з активного використання. Така послідовність не є формальною частиною криптографічної побудови, але без неї заявлена практична цінність гібридизації була б неповною.

Окремого значення набуває операційна сумісність із прикладною логікою сервісу. Для більшості реальних систем протокол автентифікації не існує ізольовано: він взаємодіє з лімітами спроб входу, журналюванням, механізмами відновлення доступу, антифрод-аналізом та обов'язковими регуляторними вимогами до аудиту. Саме тому в роботі акцентовано не лише на криптографічній коректності, а й на стабільності FFI-контракту, детермінованому серіалізаційному форматі та явній перевірці версій. Якщо ці аспекти лишити поза рукописом, то практична придатність схеми буде істотно переоціненою навіть за бездоганної символічної моделі.

Не менш важливим є питання контрольованої деградації сервісу у випадку часткових збоїв. Для гібридних схем це означає потребу розділяти криптографічну помилку, помилку узгодження версії та транспортну помилку, оскільки для оператора вони мають різні наслідки й різні процедури реагування. Якщо збій ML-KEM-ланцюжка буде сприйнято як звичайну невдачу спробу входу, то система обліку інцидентів втратить можливість

відрізняти реальну атаку від помилки сумісності або дефекту клієнта. Тому версіонування мережевого формату та стабільний FFI-контракт мають не лише інженерний, а й методологічний сенс: вони роблять можливими коректні операційні висновки з телеметрії та забезпечують спостережуваність безпекових подій у перехідний період.

7.4 Відтворюваність як окрема дослідницька чеснота

Для робіт на перетині криптографії та системної безпеки відтворюваність є не допоміжною ознакою, а частиною аргументації. Чимало публікацій у сфері post-quantum migration обмежуються або абстрактним описом гібридизації, або локальним бенчмарком без можливості перевірити, як саме зіставлено формальну модель, реалізацію та вимірювальний контур. У запропонованій роботі ці три шари навмисно зведено разом: математичне ядро виражено через однозначно описаний мережевий формат і функції виведення ключів, символічні властивості зафіксовано окремими моделями, а реалізаційні твердження спираються на виконуваний код, який відтворює той самий протокольний сценарій.

Таке поєднання важливе ще й тому, що воно дозволяє відрізнити власне криптографічну ідею від артефактів конкретної реалізації. Наприклад, AND-інтерпретація гібридного комбінатора належить до рівня теоретичного моделювання і має читатися разом із межами Tamarin-абстракції. Натомість коректність розбору полів, відкидання неканонічних точок, поводження з невідомими версіями та повторним використанням стану належать уже до виконаного коду. Саме розділення цих площин дає змогу рецензентові побачити, де в роботі міститься формальна сила твердження, а де — інженерна доброта реалізації.

З огляду на це відтворюваність у роботі слід трактувати як окремий науковий результат: вона дає можливість незалежно перевірити не лише числа в бенчмарках, а й сам спосіб їх отримання, межі інтерпретації формальних моделей та узгодженість протокольних кроків між текстом, кодом і тестами. Для конкурсного та рецензентського читання це має безпосередню цінність, оскільки зменшує типову для security-систем розбіжність між “описаною схемою” і “системою, яку реально можна запустити”. Саме тому відкритість дослідницьких матеріалів у цій роботі виконує не роль ілюстративного доповнення, а роль невід’ємної частини доведення її прикладної зрілості.

У ширшому контексті це важливо ще й для міждисциплінарного читання роботи. Для криптографа центральним буде питання сили формального твердження; для системного дослідника — питання повторюваності вимірювань і переносимості програмного артефакту; для інженера безпеки — питання того, чи узгоджуються межі моделі з реальною операційною поверхнею атаки. Коли один і той самий рукопис дає цим трьом аудиторіям можливість перевірити вихідні припущення, хід експерименту й структуру реалізації без апеляції до неявного знання автора, це підвищує не лише довіру до результату, а й його довготривалу цінність як дослідницького орієнтира для наступних постквантових міграційних робіт.

7.5 Валідність, обмеження та подальші кроки

Робота має кілька суттєвих, але контрольованих обмежень. Реалізація є OPAQUE-подібною і не є повністю конформною до RFC 9807 та пов'язаних стандартних інтерфейсів [5]. Символьні моделі не заміняють обчислювального доведення коду реалізації, а еталонні вимірювання отримано на одній апаратній платформі, тому абсолютні мікросекундні значення слід переносити на інші архітектури обережно. Нарешті, ML-KEM-768 є відносно новим стандартом, тож гібридизація зменшує залежність від одного припущення, але не усуває потреби в подальшому криптоаналізі постквантового шару.

Подальший розвиток роботи доцільно спрямувати в чотири напрями:

1. адаптація до RFC 9807 та пов'язаної екосистеми OPAQUE/OPRF;
2. формалізація гібридного розширення в сильнішій обчислювальній або UC-постановці [22];
3. вивчення альтернативних профілів KSF і варіантів ML-KEM для мобільних та IoT-сценаріїв;
4. інтеграція зовнішніх постквантових підписів для сценаріїв, де потрібна невідмовність, без зміни базового HMAC-підтвердження рукописання.

8 Висновки

Отримані результати дають підстави розглядати гібридизацію OPAQUE з ML-KEM-768 як цілісну науково-інженерну конструкцію з формально описаним форматом передавання повідомлень, відтворюваними моделями, повноцінною Rust-реалізацією та кількісною оцінкою накладних витрат.

Теоретичний внесок. Запропоновано конструкцію Hybrid PQ-OPAQUE, у якій ML-KEM-768 інтегровано як невід'ємну складову протоколу, а не як зовнішнє доповнення до класичного OPAQUE. Ключовий матеріал формується комбінатором (17) з розширеним транскриптом (16); у межах прийнятої моделі цей комбінатор є сумісним з AND-інтерпретацією безпеки на рівні ключового матеріалу (див. інтерпретаційне твердження в розд. 4). Четвертий добуток Діффі-Геллмана ($dh_4 = e_S \cdot E_C$) посилює зв'язування сторін; його можливий внесок у стійкість до UKS-подібних підстановок у цій роботі розглядається як дизайн-мотивація. Успадковані від OPAQUE цілі aPAKE у цій роботі розглядаються крізь сукупність тверджень про межі офлайн-перебирання, тверджень про пряму секретність і взаємну автентифікацію, а також символічних моделей і тестових матеріалів у межах явно зафіксованої моделі загроз.

Верифікаційний внесок.

- **ProVerif 2.05:** 5/5 запитів підтверджено у двох окремих моделях (секретність та автентифікація);
- **Tamarin Prover 1.10.0:** 8/8 лем підтверджено в архівованій сурогатній 4DH-моделі за 22,83 с; зокрема пряма секретність (119 кроків) та AND-модель (29 кроків);

- формальні моделі та журнали верифікації інтерпретуються як символічна доказова база, а не як машинно перевірене доведення коду реалізації.

Реалізаційний та вимірювальний внесок.

- **155 тестів пройдено, 1 пропущено** у поточному просторі проєктів;
- наскрізний цикл автентифікації = **481,43 мс** (95% ДІ [471,73; 495,25]); ізолюваний профіль Argon2id = 510,86 мс; ML-KEM-768 = 122,01 мкс. Ці числа походять з окремих сценаріїв Criterion і не є адитивними;
- ізолюване формування KE2 = **254,26 мкс**, тоді як завершальна перевірка респондера = 760,82 нс;
- постквантові накладні витрати: +159,3 **мкс** (+30,1%) без KSF; **близько 0,03%** від наскрізного часу; +2272 байти у мережевому форматі (+516%) при незмінних 1,5 обмінах.

У сукупності отримані результати дають підстави розглядати Hybrid PQ-OPAQUE не як абстрактну гібридну ідею, а як відтворюваний крок до постквантового підсилення пароліної автентифікації. Принципово важливо, що порівняно з класичним OPAQUE інтеграція ML-KEM-768 не змінює кількості раундів і не переводить протокол в інший клас обчислювальної складності для чесних сторін; зростання ціни має адитивний характер і концентрується головно в мережевому обсязі рукописування. Натомість у межах прийнятої моделі умова компрометації фінального ключового матеріалу стає структурно сильнішою, оскільки гібридний комбінатор зберігає змістовну перехідну цінність доти, доки принаймні одне з двох джерел ключового матеріалу лишається обчислювально стійким.

Водночас практичне читання цих результатів вимагає академічної стриманості. Формальні висновки слід інтерпретувати разом із межами символічної моделі, а твердження про словникову стійкість поширюються лише на сценарій компрометації бази даних без компрометації σ_{orpf} . Саме узгодження формальної моделі, відкритої реалізації та відтворюваного кількісного результату і становить головну цінність роботи.

Література

1. Boneau J., Herley C., van Oorschot P.C., Stajano F. The quest to replace passwords: A framework for comparative evaluation of web authentication schemes // Proc. IEEE S&P 2012. — P. 553–567.
2. Florencio D., Herley C. A large-scale study of web password habits // Proc. WWW 2007. — P. 657–666.
3. Bellare M., Pointcheval D., Rogaway P. Authenticated key exchange secure against dictionary attacks // EUROCRYPT 2000, LNCS 1807. — Springer, 2000. — P. 139–155.
4. Jarecki S., Krawczyk H., Xu J. OPAQUE: An asymmetric PAKE protocol secure against pre-computation attacks // EUROCRYPT 2018, LNCS 10822. — Springer, 2018. — P. 456–486.

5. Bourdrez D., Krawczyk H., Lewi K., Wood C.A. The OPAQUE Augmented Password-Authenticated Key Exchange (aPAKE) Protocol // IRTF RFC 9807. — July 2025. — URL: <https://www.rfc-editor.org/info/rfc9807>.
6. Shor P.W. Algorithms for quantum computation: Discrete logarithms and factoring // FOCS 1994. — P. 124–134.
7. Bernstein D. J., Lange T. Post-quantum cryptography // Nature. — 2017. — Vol. 549, No. 7671. — P. 188–194.
8. Roetteler M., Naehrig M., Svore K. M., Lauter K. Quantum resource estimates for computing elliptic curve discrete logarithms // ASIACRYPT 2017, LNCS 10625. — Springer, 2017. — P. 241–270.
9. Babbush R., Zalcman A., Gidney C., Broughton M., Khattar T., Neven H., Bergamaschi T., Drake J., Boneh D. Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations // Google Quantum AI Whitepaper. — March 30, 2026. — URL: <https://quantumai.google/static/site-assets/downloads/cryptocurrency-whitepaper.pdf>.
10. Mosca M. Cybersecurity in an era with quantum computers: Will we be ready? // IEEE Security & Privacy. — 2018. — Vol. 16, No. 5. — P. 38–41.
11. National Institute of Standards and Technology. Module-Lattice-Based Key-Encapsulation Mechanism Standard: FIPS 203. — 2024. — URL: <https://csrc.nist.gov/pubs/fips/203/final>.
12. National Institute of Standards and Technology. Module-Lattice-Based Digital Signature Standard: FIPS 204. — 2024. — URL: <https://csrc.nist.gov/pubs/fips/204/final>.
13. Stebila D., Fluhrer S., Gueron S. Hybrid key exchange in TLS 1.3 // IETF Internet-Draft draft-ietf-tls-hybrid-design-16 (work in progress). — September 2025. — URL: <https://datatracker.ietf.org/doc/draft-ietf-tls-hybrid-design/>.
14. Brendel J., Fiedler R., Günther F., Jacobsen C., Poettering B. Post-quantum security of the Signal protocol // SAC 2020, LNCS 12804. — Springer, 2020. — P. 567–591.
15. Hülsing A., Ning K.-C., Schwabe P., Weber F., Zimmermann P. R. Post-quantum WireGuard // IEEE S&P 2021. — P. 304–321.
16. Boyko V., MacKenzie P., Patel S. Provably secure password-authenticated key exchange using Diffie-Hellman // EUROCRYPT 2000, LNCS 1807. — Springer, 2000. — P. 156–171.
17. Bellare S. M., Merritt M. Encrypted key exchange: Password-based protocols secure against dictionary attacks // IEEE S&P 1992. — P. 72–84.
18. Ladd W., Kaduk B., Harkins D. SPAKE2, a PAKE // IETF RFC 9382. — 2023.
19. Haase B., Labrique B. AuCPace: Efficient verifier-based PAKE protocol tailored for the IIoT // IACR TCHES. — 2019. — Vol. 2019, No. 2. — P. 1–48.
20. Wu T. The Secure Remote Password protocol // NDSS 1998. — P. 97–111.
21. de Valence H., Grigg J., Hamburg M., Lovecruft I., Tankersley G., Valsorda F. The ristretto255 and decaf448 groups // IRTF RFC 9496. — December 2023. — URL: <https://www.rfc-editor.org/info/rfc9496>.
22. Canetti R. Universally composable security: A new paradigm for cryptographic protocols // FOCS 2001. — P. 136–145.
23. Krawczyk H., Eronen P. HMAC-based Extract-and-Expand Key Derivation Function (HKDF) // IETF RFC 5869. — 2010.
24. Cremers C., Mauw S. Operational Semantics and Verification of Security Protocols. — Springer, 2012.
25. Basin D., Cremers C., Meadows C. Model checking security protocols // Handbook of Model Checking. — Springer, 2018. — P. 727–762.

26. Biryukov A., Dinu D., Khovratovich D. Argon2: New generation of memory-hard functions for password hashing // IEEE Euro S&P 2016. — P. 292–302.
27. Heyer C. et al. Criterion.rs: Statistics-driven micro-benchmarking in Rust. — URL: <https://github.com/bheisler/criterion.rs>. — 2023.
28. Beguinet H. et al. Get Me out of This Lattice: CRYSTALS-Kyber and Post-Quantum Signal // ACM CCS 2023.
29. Arriaga A., Barbosa M., Jarecki S., Skrobot M. C'est très CHIC: A compact password-authenticated key exchange from lattice-based KEM // Cryptology ePrint Archive. — Paper 2024/308. — 2024. — URL: <https://eprint.iacr.org/2024/308>.
30. Hesse J., Rosenberg M. PAKE combiners and efficient post-quantum instantiations // EUROCRYPT 2025, LNCS 15602. — Springer, 2025. — P. 395–420.
31. Lyu Y., Liu S., Han S. Universal composable password authenticated key exchange for the post-quantum world // EUROCRYPT 2024, LNCS 14657. — Springer, 2024. — P. 120–150.
32. Lyu Y., Liu S. Hybrid password authentication key exchange in the UC framework // EUROCRYPT 2025, LNCS 15602. — Springer, 2025. — P. 421–450.
33. Vos J., Jarecki S., Wood C. A. Hybrid Post-Quantum Password Authenticated Key Exchange // Individual Internet-Draft draft-vos-cfrg-pqpake-00. — April 2025. — URL: <https://datatracker.ietf.org/doc/draft-vos-cfrg-pqpake/00/>.
34. Castryck W., Decru T. An efficient key recovery attack on SIDH // EUROCRYPT 2023, LNCS 14008. — Springer, 2023. — P. 423–447.